ROCKET 4 RPO

CHECKLIST JURIDIQUE

Checklist RGPD Recrutement

Les 40 points de conformité pour protéger les données candidats et éviter les sanctions CNIL.

40	24 mois	72h
POINTS DE CONFORMITÉ	CONSERVATION MAX CNIL	DÉLAI NOTIFICATION

MODE D'EMPLOI

📖 Comment utiliser cette checklist

1. Parcourez les 9 sections thématiques pour identifier vos écarts de conformité actuels.
2. Servez-vous des tableaux de référence (bases légales, durées, droits) pour cadrer votre politique candidat.
3. Utilisez l'audit 40 points final comme contrôle annuel DPO (fiche de synthèse imprimable).

⏱ **Lecture :** 18 min 🎯 **Pour qui :** DPO, DRH, TA Manager, Legal Ops

📊 **Maturité :** Senior — connaissances RGPD préalables utiles

40	24 mois	72h
POINTS DE CONFORMITÉ	CONSERVATION MAX CNIL	DÉLAI NOTIFICATION VIOLATION

Le RGPD (Règlement général sur la Protection des Données, UE 2016/679) s'applique à toute collecte de données personnelles de candidats. Les sanctions peuvent atteindre 20 millions d'euros ou 4% du chiffre d'affaires mondial. Cette checklist couvre les obligations essentielles pour un processus de recrutement conforme en France.

Avertissement : Ce document est un guide pratique de conformité. Il ne remplace pas l'avis d'un DPO ou d'un avocat spécialisé en protection des données. Les références d'articles renvoient au RGPD (UE 2016/679) et au Code du travail français.

Base légale du traitement (Art. 6 RGPD)

Quelle base légale pour le recrutement ?
La CNIL recommande l'**intérêt légitime** (Art. 6.1.f) comme base légale principale pour le traitement des candidatures spontanées ou en réponse à une offre. Le consentement (Art. 6.1.a) n'est pas adapté en raison du déséquilibre entre le candidat et le recruteur.

BASE LÉGALE	ARTICLE RGPD	USAGE EN RECRUTEMENT	CONDITION
Intérêt légitime	Art. 6.1.f	Traitement des candidatures	Test de mise en balance obligatoire

Mesures précontractuelles	Art. 6.1.b	Vérification des diplômes, prise de références	À la demande du candidat
Consentement	Art. 6.1.a	Constitution du vivier (conservation post-process)	Libre, spécifique, éclairé, univoque
Obligation légale	Art. 6.1.c	Vérifications réglementaires (casier, habilitations)	Métiers réglementés uniquement

- ☐ La base légale du traitement est identifiée et documentée pour chaque finalité
- ☐ Un test de mise en balance des intérêts a été réalisé (intérêt employeur vs droits candidat) si la base est l'intérêt légitime
- ☐ Le consentement est utilisé uniquement pour le vivier de candidats (conservation au-delà du process de recrutement)
- ☐ Le consentement est recueilli via un formulaire dédié, distinct du formulaire de candidature
- ☐ Le consentement est libre (pas de case pré-cochée), spécifique, éclairé et univoque (Art. 7)

Information des candidats (Art. 13 et 14 RGPD)

L'article 13 impose une information complète du candidat au moment de la collecte directe. L'article 14 s'applique lorsque les données sont obtenues indirectement (sourcing LinkedIn, cooptation).

Mentions obligatoires (Art. 13.1 et 13.2)

#	INFORMATION REQUISE	RÉF. RGPD	CONFORME
1	Identité et coordonnées du responsable de traitement	Art. 13.1.a	
2	Coordonnées du DPO (si désigné)	Art. 13.1.b	
3	Finalités du traitement et base légale	Art. 13.1.c	
4	Intérêts légitimes poursuivis (si Art. 6.1.f)	Art. 13.1.d	
5	Destinataires ou catégories de destinataires	Art. 13.1.e	
6	Transfert hors UE et garanties appropriées	Art. 13.1.f	
7	Durée de conservation ou critères de détermination	Art. 13.2.a	
8	Droits des candidats (accès, rectification, effacement, etc.)	Art. 13.2.b	
9	Droit de retrait du consentement (si applicable)	Art. 13.2.c	

10	Droit de réclamation auprès de la CNIL	Art. 13.2.d
11	Caractère obligatoire ou facultatif de la fourniture des données	Art. 13.2.e
12	Existence d'une décision automatisée ou profilage	Art. 13.2.f

- ☐ Une politique de confidentialité candidat est rédigée et accessible sur le site carrière
- ☐ L'information est fournie au moment de la collecte (formulaire, offre d'emploi)
- ☐ En cas de sourcing (LinkedIn, GitHub), le candidat est informé dans le premier message (Art. 14.3 : délai max 1 mois)
- ☐ Les mentions légales sont présentées sur chaque formulaire de candidature

EXEMPLE PRÉ-REMPLI

Extrait type — politique de confidentialité candidat (3 articles essentiels)

Article 1 — Finalité du traitement
Les données personnelles que vous nous transmettez (identité, coordonnées, CV, lettre de motivation, notes d'entretien, résultats d'évaluation) sont collectées par [Nom de l'entreprise], responsable de traitement, dans le cadre exclusif du traitement de votre candidature et, le cas échéant, de la gestion de la relation contractuelle en cas d'embauche. Base légale : intérêt légitime (Art. 6.1.f RGPD) pour le process de recrutement ; consentement (Art. 6.1.a) pour la conservation dans notre vivier au-delà.

Article 2 — Durée de conservation
Vos données sont conservées pendant toute la durée du processus de recrutement. Si votre candidature n'aboutit pas, vos données sont supprimées au plus tard 24 mois après notre dernier contact, conformément aux recommandations de la CNIL (délibération n°2002-17). Avec votre consentement explicite, nous pouvons les conserver plus longtemps dans notre vivier pour vous proposer d'autres opportunités — durée renouvelable par reconsentement.

Article 3 — Vos droits
Conformément aux articles 15 à 22 du RGPD, vous disposez d'un droit d'accès, de rectification, d'effacement, de limitation, de portabilité et d'opposition sur vos données, ainsi que du droit de retirer votre consentement à tout moment. Vous pouvez exercer ces droits en écrivant à [email DPO/recrutement] ; nous répondons sous 1 mois (prolongeable de 2 mois si la demande est complexe). Vous avez également le droit d'introduire une réclamation auprès de la CNIL (www.cnil.fr).

Données collectées — Principe de minimisation (Art. 5.1.c)

Seules les données adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées doivent être collectées.

DONNÉE	COLLECTE AUTORISÉE	CONDITION
Données d'identification		
Nom, prénom	Oui	Nécessaire
Email, téléphone	Oui	Contact candidat
Adresse postale	Oui (si pertinent)	Mobilité / zone géographique
Photo	Déconseillé	Non pertinent sauf métiers de représentation
Données professionnelles		
CV, lettre de motivation	Oui	Évaluation des compétences
Expérience professionnelle	Oui	En lien avec le poste
Formation, diplômes	Oui	Si requis pour le poste
Prétentions salariales	Oui	Adéquation budget
Disponibilité, préavis	Oui	Planification embauche
Permis de conduire	Oui si justifié	Poste nécessitant un véhicule
Données interdites (Art. 9 — Données sensibles)		
Numéro de sécurité sociale	INTERDIT	Uniquement après embauche
Situation familiale, grossesse	INTERDIT	Art. L1132-1 Code du travail
Religion, opinions politiques	INTERDIT	Art. 9.1 RGPD
Origine ethnique	INTERDIT	Art. 9.1 RGPD
État de santé	INTERDIT	Compétence médecin du travail
Appartenance syndicale	INTERDIT	Art. 9.1 RGPD
Casier judiciaire	INTERDIT (sauf exception)	Métiers réglementés uniquement

- ☐ Les formulaires de candidature ne contiennent pas de champs non pertinents (âge, situation familiale, nationalité)
- ☐ Les notes d'entretien ne contiennent aucun commentaire discriminatoire ou donnée sensible
- ☐ Un audit annuel des champs collectés est réalisé

Durée de conservation (Art. 5.1.e et Art. 17)

Recommandation CNIL : Les données des candidats non retenus doivent être supprimées au plus tard **24 mois** après le dernier contact, sauf consentement explicite pour une durée plus longue (délibération CNIL n°2002-17).

SITUATION	DURÉE MAXIMALE	BASE LÉGALE	ACTION REQUISE
Candidature en cours de process	Durée du recrutement	Intérêt légitime	Suppression à la clôture du poste
Candidat non retenu	24 mois max	Intérêt légitime	Suppression automatique ou manuelle
Vivier avec consentement	24 mois renouvelables	Consentement (Art. 6.1.a)	Renouvellement explicite avant expiration
Candidat embauché	Durée du contrat + 5 ans	Obligation légale	Transfert vers dossier RH
Données de recrutement archivées	5 ans	Art. 2224 Code civil	Archivage intermédiaire sécurisé

- ☐ Une politique de purge automatique est paramétrée dans l'ATS (suppression à 24 mois)
- ☐ Les candidats sont informés de la durée de conservation dans la politique de confidentialité
- ☐ Un process de renouvellement du consentement est en place pour le vivier (email de reconfirmation)
- ☐ Les CV imprimés sont détruits par broyage après numérisation (Art. 5.1.f)
- ☐ Un registre de suppression est tenu (date, volume, méthode)

Droits des candidats (Art. 15 à 22)

DROIT	ARTICLE	DÉLAI DE RÉPONSE	MODALITÉ
Droit d'accès	Art. 15	1 mois	Copie des données en format lisible
Droit de rectification	Art. 16	1 mois	Correction des données inexactes
Droit à l'effacement	Art. 17	1 mois	Suppression si plus de base légale
Droit à la limitation	Art. 18	1 mois	Gel du traitement en cas de contestation
Droit à la portabilité	Art. 20	1 mois	Export en format structuré (CSV, JSON)
Droit d'opposition	Art. 21	1 mois	Opposition au traitement (intérêt légitime)

Décision individuelle automatisée	Art. 22	1 mois	Droit à une intervention humaine

- [ ] Un processus interne est en place pour traiter les demandes dans le délai légal (1 mois, prolongeable de 2 mois si complexe)
- [ ] Les coordonnées pour exercer les droits sont publiées dans la politique de confidentialité
- [ ] Un registre des demandes d'exercice de droits est tenu
- [ ] L'identité du demandeur est vérifiée avant communication des données

Sécurité des données (Art. 32)

Le responsable de traitement et le sous-traitant doivent mettre en oeuvre les mesures techniques et organisationnelles appropriées pour garantir un niveau de sécurité adapté au risque.

- [ ] Les CV et données candidats sont stockés dans un système sécurisé (ATS, espace chiffré)
- [ ] L'accès aux données est limité aux personnes habilitées (recruteurs, hiring managers du poste concerné)
- [ ] L'authentification forte est activée sur l'ATS (MFA / 2FA)
- [ ] Les mots de passe respectent les recommandations CNIL 2022 (12 caractères min, complexité)
- [ ] Les échanges de CV par email sont limités — le partage via ATS est privilégié
- [ ] Aucun CV n'est stocké sur des espaces partagés non sécurisés (Google Drive public, Slack, WhatsApp)
- [ ] Les postes de travail accédant aux données candidats disposent d'un antivirus à jour et d'un chiffrement disque
- [ ] Un registre des violations de données est tenu (Art. 33 : notification CNIL sous 72h en cas de violation)

Sous-traitants et transferts (Art. 28 et Art. 44-49)

Contrats sous-traitants (Art. 28)

Tout sous-traitant qui traite des données candidats pour votre compte doit être encadré par un contrat incluant les clauses de l'Art. 28.3.

- [ ] Un registre des sous-traitants traitant des données candidats est à jour

- [ ] Des clauses RGPD (Art. 28.3) sont incluses dans les contrats avec :

SOUS-TRAITANT	DONNÉES TRAITÉES	CLAUSE ART. 28	TRANSFERT HORS UE
ATS / logiciel de recrutement	CV, identité, historique candidature		
Cabinets de recrutement / RPO	CV, notes d'entretien, évaluations		
Plateformes de tests / assessments	Résultats, identité		
Outils de visioconférence	Enregistrements (si applicable)		
Outils d'emailing / CRM candidat	Email, prénom, historique échanges		
Outils d'IA (ChatGPT, Claude, etc.)	Données saisies dans les prompts		

- [ ] En cas de transfert hors UE : clauses contractuelles types (CCT) ou décision d'adéquation (Art. 45)

- [ ] Les sous-traitants américains sont encadrés par le EU-US Data Privacy Framework ou des CCT (Art. 46)

- [ ] Aucune donnée candidat n'est copiée dans un outil d'IA sans anonymisation préalable

IA et recrutement (AI Act + RGPD)

AI Act européen (Règlement UE 2024/1689) : Les systèmes d'IA utilisés dans le recrutement sont classés **« haut risque »** (Annexe III, point 4). Ils sont soumis à des obligations renforcées : évaluation de conformité, gestion des risques, transparence, supervision humaine et documentation technique.

- [ ] Les outils d'IA utilisés dans le recrutement sont documentés (registre des traitements + registre AI Act)

- [ ] Une analyse d'impact (AIPD / DPIA, Art. 35) est réalisée si traitement automatisé à grande échelle

- [ ] Les candidats sont informés de l'utilisation d'outils automatisés (Art. 13.2.f et Art. 22)

- [ ] Une intervention humaine est garantie dans la décision finale de recrutement (Art. 22.3)

- [ ] Les biais algorithmiques sont audités au moins une fois par an
- [ ] Les données candidats ne sont pas utilisées pour entraîner des modèles d'IA sans consentement

Registre des traitements (Art. 30)

Toute entreprise de 250+ salariés ou tout responsable de traitement dont le traitement est susceptible de comporter un risque pour les droits et libertés des personnes doit tenir un registre.

ÉLÉMENT DU REGISTRE	EXEMPLE RECRUTEMENT
Finalité du traitement	Gestion des candidatures et recrutement de collaborateurs
Catégories de personnes	Candidats (externes et internes)
Catégories de données	Identité, CV, notes d'entretien, évaluations, références
Destinataires	Équipe recrutement, hiring managers, sous-traitants (ATS, outils)
Durée de conservation	24 mois après dernier contact (candidats non retenus)
Mesures de sécurité	Chiffrement, contrôle d'accès, MFA, pseudonymisation
Transferts hors UE	Oui/Non — si oui, garanties (CCT, adéquation, EU-US DPF)

- [ ] Le traitement « recrutement » est inscrit au registre des traitements
- [ ] Le registre est mis à jour au moins une fois par an ou à chaque changement d'outil
- [ ] Le registre est accessible au DPO et à la CNIL en cas de contrôle

! **Audit annuel obligatoire :** le registre des traitements doit être tenu à jour et révisé au moins une fois par an (Art. 30 RGPD). Les sanctions en cas de manquement peuvent atteindre jusqu'à 4% du chiffre d'affaires annuel mondial ou 20 M€ (Art. 83 RGPD) — la valeur la plus élevée étant retenue.

Modèle de formulaire de consentement (vivier)

Modèle de clause consentement vivier :

« J'autorise [Nom de l'entreprise] à conserver mes données personnelles (CV, coordonnées, notes d'entretien) dans son vivier de candidats pour une durée de 24 mois à compter de ce jour, dans le but d'être recontacté(e) pour des opportunités correspondant à mon profil. Je comprends que je peux retirer ce

consentement à tout moment en écrivant à [email DPO/recrutement]. Ce retrait n'affectera pas la licéité du traitement effectué avant le retrait. »

Signature : _____ Date : __ / __ / ____

Audit RGPD — 40 points de contrôle booléens

Grille de contrôle synthétique à parcourir annuellement ou avant un audit CNIL. Chaque item renvoie aux sections précédentes pour le détail. Objectif : statut conforme / non conforme, sans re-explication.

§ 1 — BASE LÉGALE (ART. 6)

- ☐ Base légale identifiée par finalité
- ☐ Test de mise en balance documenté (Art. 6.1.f)
- ☐ Consentement recueilli uniquement pour le vivier
- ☐ Consentement libre, spécifique, éclairé, univoque

§ 2 — INFORMATION CANDIDATS (ART. 13/14)

- ☐ Politique confidentialité publiée site carrière
- ☐ 12 mentions obligatoires présentes (Art. 13.1-2)
- ☐ Info sourcing LinkedIn dans 1er message (Art. 14.3)
- ☐ Mentions légales sur chaque formulaire

§ 3 — MINIMISATION (ART. 5.1.C)

- ☐ Aucun champ discriminatoire dans les formulaires
- ☐ Notes d'entretien sans donnée sensible
- ☐ Audit annuel des champs collectés réalisé
- ☐ Photo non demandée sauf métier justifié

§ 4 — CONSERVATION (ART. 5.1.E / 17)

- ☐ Purge automatique ATS paramétrée à 24 mois
- ☐ Candidats informés de la durée dans la politique
- ☐ Process de reconsentement vivier en place
- ☐ CV imprimés détruits par broyage + registre suppression

§ 5 — DROITS CANDIDATS (ART. 15-22)

- ☐ Process interne de traitement des demandes 1 mois
- ☐ Coordonnées d'exercice publiées
- ☐ Registre des demandes de droits tenu
- ☐ Identité demandeur systématiquement vérifiée

§ 6 — SÉCURITÉ (ART. 32)

- ☐ Stockage dans ATS sécurisé uniquement
- ☐ Accès limité aux personnes habilitées
- ☐ MFA/2FA activé sur l'ATS
- ☐ Mots de passe conformes recommandations CNIL 2022

- ☐ Aucun CV sur espaces non sécurisés (WhatsApp, Drive public)
- ☐ Registre des violations tenu (notification 72h)

§ 7 — SOUS-TRAITANTS (ART. 28 / 44-49)

- ☐ Registre des sous-traitants à jour
- ☐ Clauses Art. 28.3 dans tous les contrats
- ☐ CCT ou adéquation pour transferts hors UE
- ☐ Pas de données candidat dans IA sans anonymisation

§ 8 — IA RECRUTEMENT (AI ACT)

- ☐ Outils IA documentés (registre + AI Act)
- ☐ AIPD/DPIA réalisée si applicable
- ☐ Candidats informés de l'utilisation d'IA
- ☐ Intervention humaine garantie dans décision finale
- ☐ Biais algorithmiques audités annuellement

§ 9 — REGISTRE (ART. 30) + GOUVERNANCE

- ☐ Traitement « recrutement » inscrit au registre
- ☐ Registre révisé au moins 1x/an
- ☐ Registre accessible au DPO et à la CNIL
- ☐ Hiring managers formés au RGPD (1x/an min)
- ☐ Aucune violation non signalée identifiée

Score cible : 40/40. En dessous de 36/40, engager un plan de remédiation sous 30 jours avec le DPO. En dessous de 30/40, risque élevé en cas de contrôle CNIL.

🛡 **Audit RGPD recrutement complet**

Diagnostic gratuit : on passe en revue votre conformité et livrons un plan de remédiation chiffré.

Lancer le diagnostic →

📚 RESSOURCES COMPLÉMENTAIRES

GUIDE
Recrutement inclusif

TEMPLATE
Offre d'emploi

GUIDE
IA et recrutement

📚 SOURCES & RÉFÉRENCES

1. CNIL — Fiche pratique recrutement et protection des données : cnil.fr/fr/recrutement
2. RGPD — Règlement (UE) 2016/679, texte de référence
3. AI Act — Règlement (UE) 2024/1689 relatif à l'intelligence artificielle (Annexe III, point 4 : recrutement haut risque)
4. Défenseur des Droits — Guide pour prévenir les discriminations à l'embauche : defenseurdesdroits.fr
5. Données internes Rocket4RPO — 200+ recrutements 2024-2026

ROCKET4RPO

rocket4rpo.com — Tous droits réservés 2026

Données issues de 200+ recrutements réalisés